

Risk Assessment

PREPARED BY: ABDULREHMAN MASUOD RAJAB

Step 1

Introduction

Risk assessment is a critical component of cybersecurity management. It enables organizations to identify potential threats, evaluate their impact, and determine appropriate mitigation strategies. This report examines both external and internal risks that may affect an organization's information systems, infrastructure, and data. It also evaluates the potential consequences of these risks and determines the organization's tolerance level for each identified threat.

Identify the company's external and internal risks. As you work to identify risks, think of the following questions:

- What external risks might the company face given the location of the servers and company headquarters?
- What internal risks might the company face with employees working remotely and at headquarters?

Explain why the company should consider each risk that you identify.

External Risks

1. Cyberattacks (Ransomware, Malware, and DDoS Attacks)

Cyberattacks pose a significant threat to organizational security. Attackers may target company servers, applications, or networks to disrupt operations, steal sensitive information, or demand ransom payments. Organizations must consider this risk because cyberattacks continue to increase in frequency and sophistication.

2. Natural Disasters (Floods, Fires, and Earthquakes)

- Natural disasters can cause severe physical damage to servers, networking equipment, and other critical infrastructure. Such events may result in data loss, service interruptions, and costly recovery efforts.

3. Power Outages

- power failures can disrupt the availability of critical systems and services. Organizations should consider this risk because prolonged outages can negatively impact business continuity and productivity.

4. Prompt Injection & AI Model Exploitation

- Attackers manipulate AI prompts to bypass security guardrails, exposing internal system data or forcing the AI to execute unauthorized commands.

5. Third-Party Vendor Breaches

- Many organizations rely on suppliers, contractors, and cloud service providers. If a third-party vendor experiences a security breach, sensitive organizational data may be exposed, even if the organization's own security controls remain effective.

Internal Risks

1. Phishing Attacks on Employees

Employees may unknowingly respond to fraudulent emails, reveal credentials, or install malicious software. Human error remains one of the most common causes of security incidents.

2. Insider Threats

Disgruntled, careless, or malicious employees may intentionally or accidentally misuse company resources, leak confidential information, or compromise systems.

3. Weak Password Practices

Weak, reused, or easily guessed passwords increase the likelihood of unauthorized access to organizational systems and sensitive data.

4. Remote Work Security Risks

Employees working remotely may use unsecured networks, personal devices, or weak security configurations, creating additional opportunities for cyberattacks.

5. Shadow AI & Model Drift Risk

Employees inadvertently train third-party LLMs on company data, or internal models output inaccurate, biased, or hallucinated responses over time.

Step 2

Describe one consequence or impact for each risk you identified in Step 1.
Explain how each risk can lead to the impact described.

1. Cyberattacks

Impact: Data Breach

Cyberattacks can result in unauthorized access to sensitive information, exposing confidential business and customer data. Leading to financial losses, legal penalties, and reputational damage.

2. Natural Disasters

Impact: Loss of Infrastructure

Floods, fires, or earthquakes may damage servers, networking equipment, and physical facilities, resulting in significant operational disruptions.

3. Power Outages

Impact: Business Downtime

Power failures can make systems unavailable, interrupting business operations and reducing employee productivity.

4. Third-Party Vendor Breaches

Impact: Data Exposure

A compromised vendor may provide attackers with indirect access to sensitive organizational information.

5. Phishing Attacks

Impact: Account Compromise

Employees who unknowingly disclose login credentials may allow attackers to gain unauthorized access to company systems.

6. Insider Threats

Impact: Data Theft

Employees may intentionally or accidentally leak, alter, or destroy sensitive information, resulting in security incidents.

7. Weak Password Practices

Impact: Unauthorized Access

Attackers can guess or crack weak passwords, enabling them to gain access to protected systems and resources.

8. Remote Work Security Risks

Impact: Malware Infection

Unsecured home networks and devices may expose organizational systems to malware and other cyber threats.

9. Shadow AI & Model Drift Risk

Impact: Data Exposure

Employees inadvertently train third-party LLMs on company data, or internal models output inaccurate, biased, or hallucinated responses over time.

10. Prompt Injection & AI Model Exploitation

Impact: Data Exposure & Breach

Attackers manipulate AI prompts to bypass security guardrails, exposing internal system data or forcing the AI to execute unauthorized commands.

STEP 3

Determine the tolerability of the risks that you identified in Step 1. Perform the following tasks for each risk:

- Rate your company’s tolerance for each risk using the system discussed before: low, moderate, high, or very high.
- Describe the risk’s frequency and the extent of the harm that it can cause.
- Explain why you rated the risk low, moderate, high, or very high.

Risk	Tolerance Level	Frequency	Harm Level	Justification
Cyberattacks	Low	High	Severe	Can cause significant financial losses and reputational damage.
Natural Disasters	Moderate	Low	Severe	Although infrequent, the impact can be devastating.
Power Outages	Moderate	Medium	Significant	Interrupts business operations and affects productivity.
Third-Party Vendor Breaches	Low	Medium	Severe	Organizations have limited control over vendor security practices.
Phishing Attacks	Low	High	Severe	A single successful phishing attack can compromise critical systems.
Insider Threats	Low	Medium	Severe	Employees often have privileged access to sensitive information.
Weak Password Practices	Low	High	High	Weak passwords are easily exploited by attackers.
Remote Work Security Risks	Moderate	High	Significant	Increased use of remote devices expands the attack surface.
Prompt Injection & AI Exploitation	Low	High	Severe	Directly bypasses application controls and compromises data confidentiality.
Shadow AI & Data Exposure	Low	High	Severe	Employees using public LLMs can accidentally leak trade secrets or private data.

Conclusion

The risk assessment identified several external and internal threats that could affect the confidentiality, integrity, and availability of organizational information systems. Cyberattacks, phishing attacks, insider threats, and weak password practices present significant cybersecurity challenges and therefore require a low risk tolerance. Natural disasters, power outages, and remote work security risks also pose substantial risks and should be managed through appropriate security controls and business continuity measures. By identifying these risks, understanding their potential impacts, and assessing their tolerability, organizations can make informed decisions to strengthen their cybersecurity posture and reduce the likelihood of security incidents.